DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK

GROUP MEMBER DETAILS

S.NO	NAME	COLLEGE NAME	EMAIL
1.	ANISHTA D	Tiruppur Kumaran College For Women	singhdurai758@gmail.com
2.	NIVETHA K	Tiruppur Kumaran College For Women	nivethak03115@gmail.com
3.	POOJA S	Tiruppur Kumaran College For Women	sakthipooja106@gmail.com
4.	DHARANI S	Tiruppur Kumaran College For Women	dharanijeyadharani3@gmail.com
5.	KEERTHANA J	Tiruppur Kumaran College For Women	kkeerthi4446@gmail.com

INTRODUCTION

With the rapid growth of cloud computing, mobile devices, and remote work environments, traditional perimeter-based security models have become increasingly ineffective. Conventional access control systems typically grant access based only on user credentials, assuming that once a user is authenticated, they can freely access system resources. However, this model exposes organizations to security threats such as credential theft, unauthorized device usage, and access from suspicious locations.

To address these challenges, modern security frameworks adopt a context-aware access control approach that evaluates multiple environmental and behavioural factors before granting access. Context-aware security mechanisms analyse real-time contextual information to determine whether an access request should be approved, limited, or denied.

ABSTRACT

With the increasing use of digital services, cloud platforms, and remote access, ensuring secure access to organizational resources has become a critical challenge. Traditional access control systems that rely only on user authentication are often insufficient to protect sensitive data from modern cyber threats. To enhance security and improve decision-making in access management, context-aware access control mechanisms are gaining importance.

This project focuses on designing and implementing a context-aware access control system that dynamically regulates access to resources based on multiple contextual factors. The system evaluates key attributes such as user identity, device posture, geographic location, and application risk level before granting or restricting access. By analysing these factors, the system can determine whether a user request is safe, suspicious, or high risk.

The proposed solution enables organizations to apply adaptive security policies that respond to real-time conditions. For example, access may be permitted when a user logs in from a trusted device and location, while additional authentication or access restrictions may be applied if the request comes from an unknown device or high-risk application.

By integrating contextual information into the access control process, this project aims to improve security, reduce unauthorized access, and provide flexible and intelligent protection for modern digital environments. The implementation demonstrates how context-aware policies can strengthen access management systems and support secure and reliable operations.

USE CASE SCENARIOS

Scenario 1: Employee Access to Internal HR System

An employee from the Human Resources department needs to access the internal HR management system to update employee records. The employee logs in using a company laptop from the office network. The system verifies the user's identity through multi-factor authentication (MFA), checks that the device meets security requirements (antivirus active and disk encryption enabled), and confirms the login location as a trusted corporate network. Since all conditions meet the security policy, the system grants secure access to the HR application.

Output:

- User authenticated using MFA
- Device posture verified as compliant
- Secure access granted only to the HR system
- Other internal systems remain restricted

Scenario 2: Remote Employee Access from an Unknown Device

A marketing employee attempts to access the company's CRM system from a personal laptop while working remotely. Although the user successfully enters correct login credentials, the system detects that the device is not registered or compliant with security policies. Because the device posture fails the security check, the system restricts access and requires additional verification.

Output:

- User identity verified but device not trusted
- Access request flagged as medium risk
- Additional authentication required or access denied
- Security team notified if suspicious activity continues

Scenario 3: Access Attempt from an Unusual Geographic Location

A manager usually logs in from the corporate office in their home country. One day, a login attempt occurs from a foreign country. The system verifies the identity but detects an

unusual geographic location. Based on the access policy, the system marks the request as high risk and requires additional authentication before granting limited access.

Output:

- Login flagged due to unusual location
- Additional authentication requested
- Limited access granted after verification
- Security alert generated for monitoring

Scenario 4: Developer Access to Source Code Repository

A software developer needs access to the company's internal Git repository to push code updates. The developer logs in using a company-approved workstation from the development network. The system verifies the developer's identity, confirms the device compliance status, and checks that the request is for a low-risk application. Based on these checks, the system grants direct access to the repository.

Output:

- User identity verified as authorized developer
- Device security posture confirmed
- Access granted only to the code repository
- Other systems remain hidden

Scenario 5: Contractor Access with Time-Based Restrictions

A temporary contractor is hired to work on a project and requires access to a specific project management tool. The contractor logs in using the assigned credentials from a registered device. The system verifies the user identity, ensures the device meets compliance standards, and applies a time-based access policy that allows usage only during business hours.

Output:

- Contractor identity verified
- Access limited to project management application
- Access allowed only during defined working hours
- Unauthorized systems remain inaccessible

STAGE – 1

Title:

Design and apply context-aware access controls based on user identity, device posture, location, and application risk

Overview of OWASP

The Open Web Application Security Project (OWASP) is a globally recognized non-profit organization dedicated to improving the security of software applications. OWASP provides free and open resources, tools, documentation, and best practices that help developers, organizations, and security professionals build secure applications and protect systems from cyber threats.

OWASP is widely known for publishing security standards and guidelines that address common vulnerabilities in web and mobile applications. One of its most popular contributions is the OWASP Top 10, which identifies the most critical security risks to web applications. These risks include issues such as broken access control, authentication failures, sensitive data exposure, security misconfigurations, and injection attacks.

In the context of this project, which focuses on designing and applying context-aware access controls, OWASP principles play an important role in strengthening application security. OWASP emphasizes secure authentication, authorization, and access control mechanisms to prevent unauthorized users from accessing sensitive resources.

By integrating these contextual parameters, the system can dynamically enforce security policies that reduce the risk of unauthorized access and potential cyberattacks. This approach also aligns with modern security frameworks such as Zero Trust Architecture, which assumes that no user or device should be trusted automatically without proper verification.

Therefore, OWASP guidelines help guide the development of secure access control systems by promoting strong authentication, secure authorization, and continuous monitoring of access activities. Implementing OWASP best practices ensures that the proposed context-aware access control system remains resilient against evolving security threats and vulnerabilities.

LIST OF VULNERABILITY:

S. No	Category Name	Vulnerability Name	CWE No
1.	Authentication Failures	Origin Validation Error	CWE-346
2.	Software or Data Integrity Failures	Untrusted Search Path	CWE-426
3.	Broken Access Control	Relative Path Traversal	CWE-23
4.	Security Misconfiguration	Configuration	CWE-16
5.	Insecure Design	Interpretation Conflict	CWE-436
6.	Software Supply Chain Failures	Use of Unmaintained Third Party Components	CWE-1104
7.	Cryptographic Failures	Insufficient Entropy	CWE-331
8.	Authentication Failures	Weak Password Requirements	CWE-521
9.	Security Misconfiguration	Active Debug Code	CWE-489
10.	Mishandling of Exceptional Conditions	Divide By Zero	CWE-369

REPORT:

1. Vulnerability Name: Origin Validation Error

CWE: 346

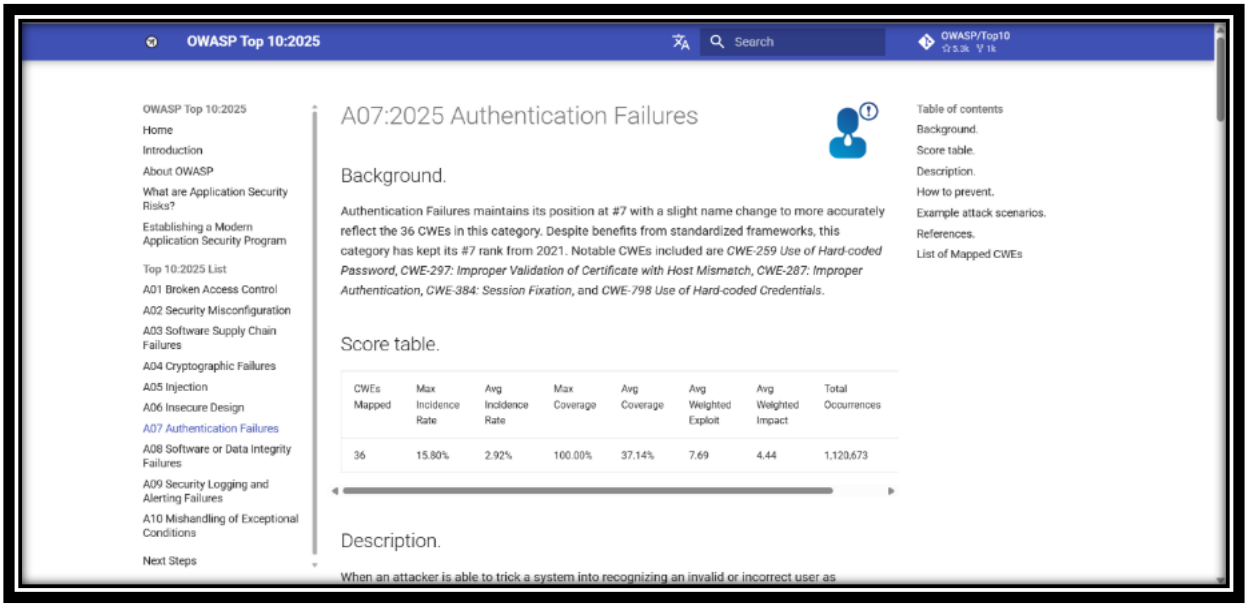
OWASP category: A07:2025 Authentication Failures

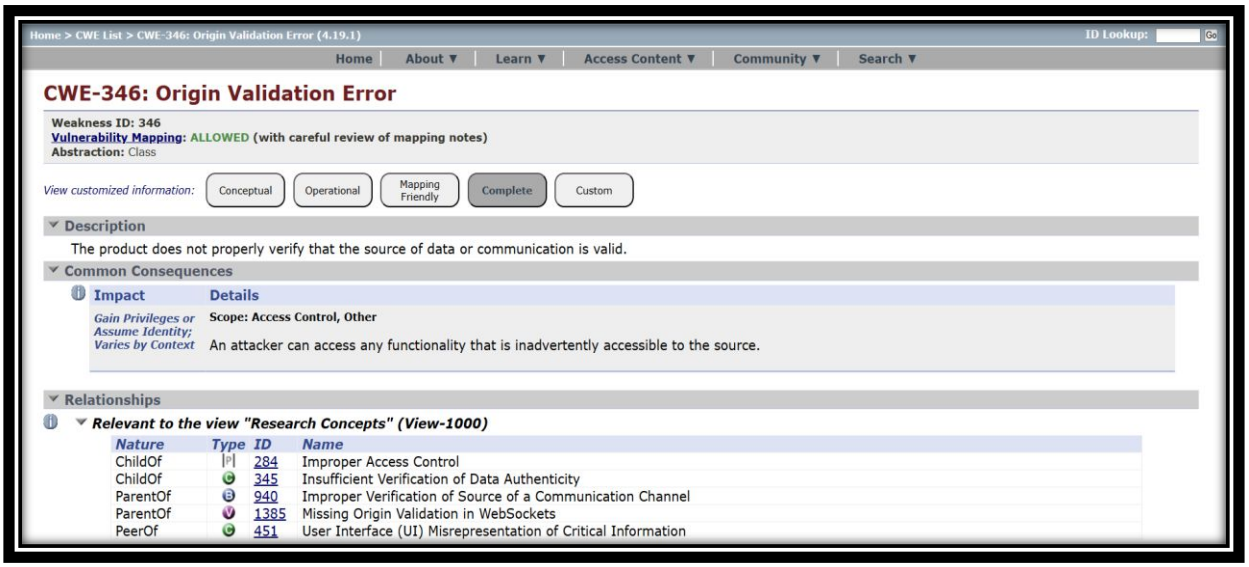
Description: Authentication failures occur when an application improperly handles user identity verification, login, or session management, allowing attackers to compromise accounts.

Business Impact: Unauthorized users may gain access to sensitive customer or company data, leading to data breaches. Organizations can suffer financial losses due to fraud, account takeovers, or service abuse. Security incidents can damage the company's brand reputation

and customer trust. Businesses may face legal penalties and regulatory compliance issues after a breach.

Vulnerability path: http://testfire.net/





2. Vulnerability Name: Untrusted Search Path

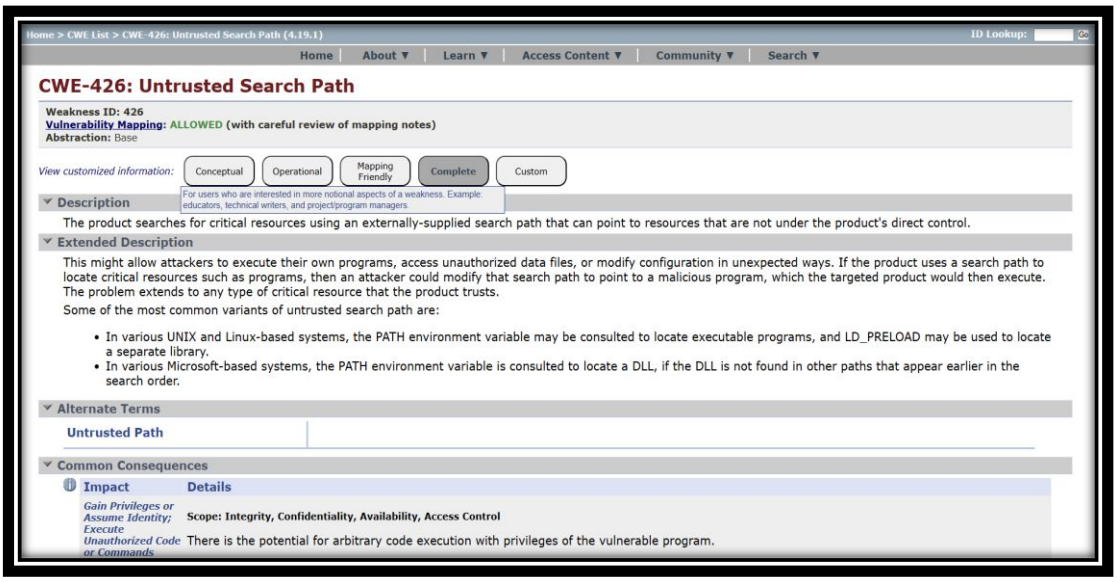
CWE: 426

OWASP category: A08:2025 Software or Data Integrity Failures

Description: Software or Data Integrity Failures occur when an application does not verify the integrity of software updates, code, or data, allowing unauthorized or malicious modifications.

Business Impact: Compromised software updates or data can allow attackers to distribute malicious code, leading to system compromise and operational disruption. Businesses may suffer financial losses due to fraud, recovery costs, and service downtime. Regulatory penalties and legal liabilities may occur if sensitive data is altered or corrupted.

Vulnerability path: http://testfire.net/



3. Vulnerability Name: Relative Path Traversal

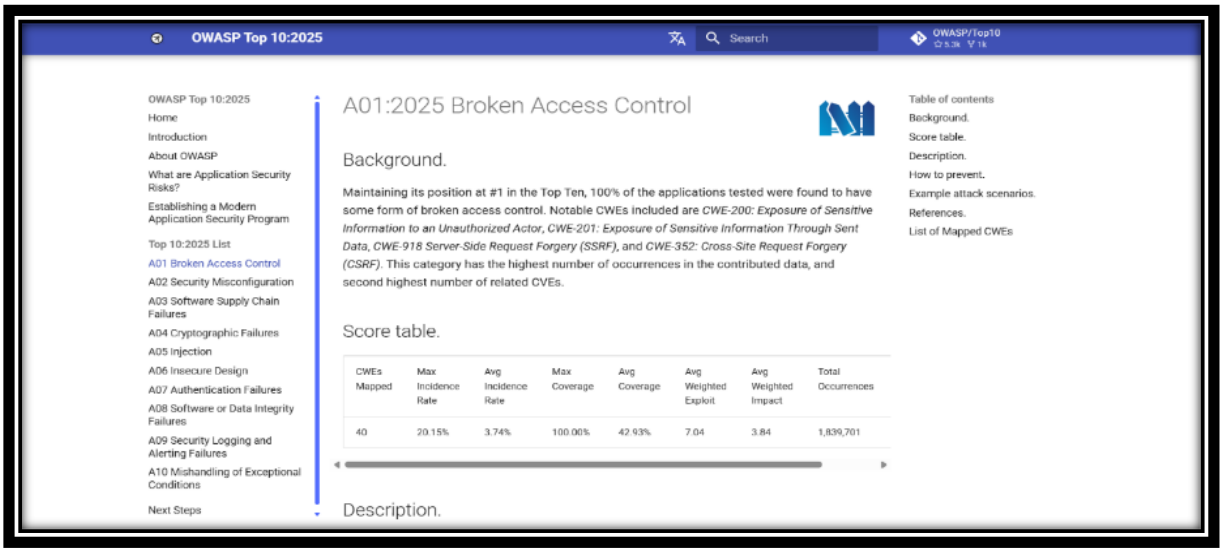
CWE: 23

OWASP category: A01:2025 Broken Access Control

Description: Broken Access Control occurs when applications fail to properly enforce restrictions on what authenticated users are allowed to do.

Business Impact: Unauthorized users may access sensitive business or customer data, leading to data breaches. Attackers could modify or delete critical information, affecting system reliability and operations. Customer trust and brand reputation can be severely damaged.

Vulnerability path: http://testfire.net/



4. Vulnerability Name: Configuration

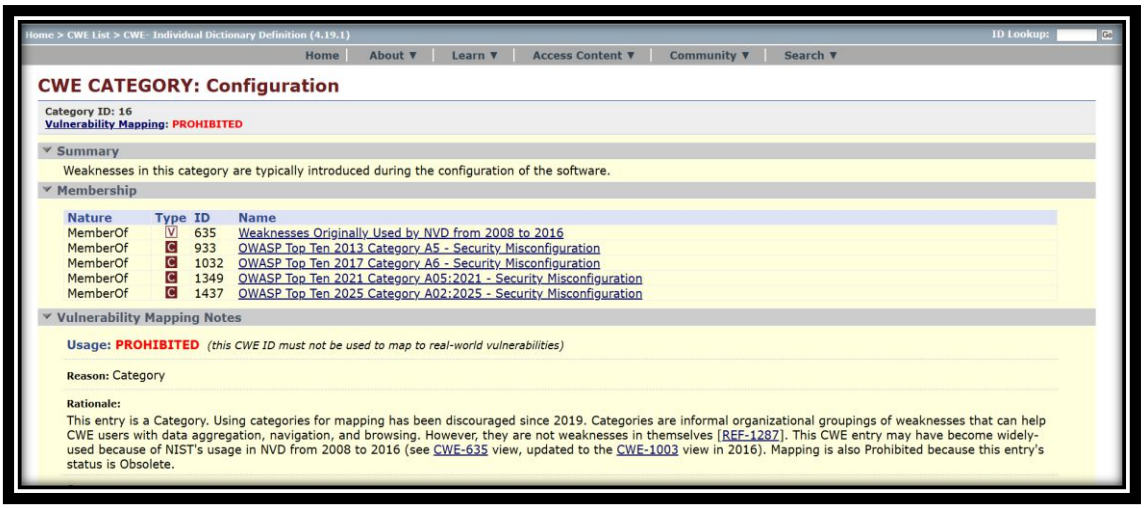
CWE-16

OWASP category: A02:2025 Security Misconfiguration

Description: Security Misconfiguration occurs when security settings are improperly configured, left as default, or not securely implemented in applications, servers, or databases.

Business Impact: Misconfigured systems can expose sensitive data, leading to data breaches and information leakage. Organizations can face financial losses due to incident response, recovery, and downtime. Poor security practices can damage brand reputation and reduce customer trust.

Vulnerability path: http://testfire.net/



5. Vulnerability Name: Interpretation Conflict

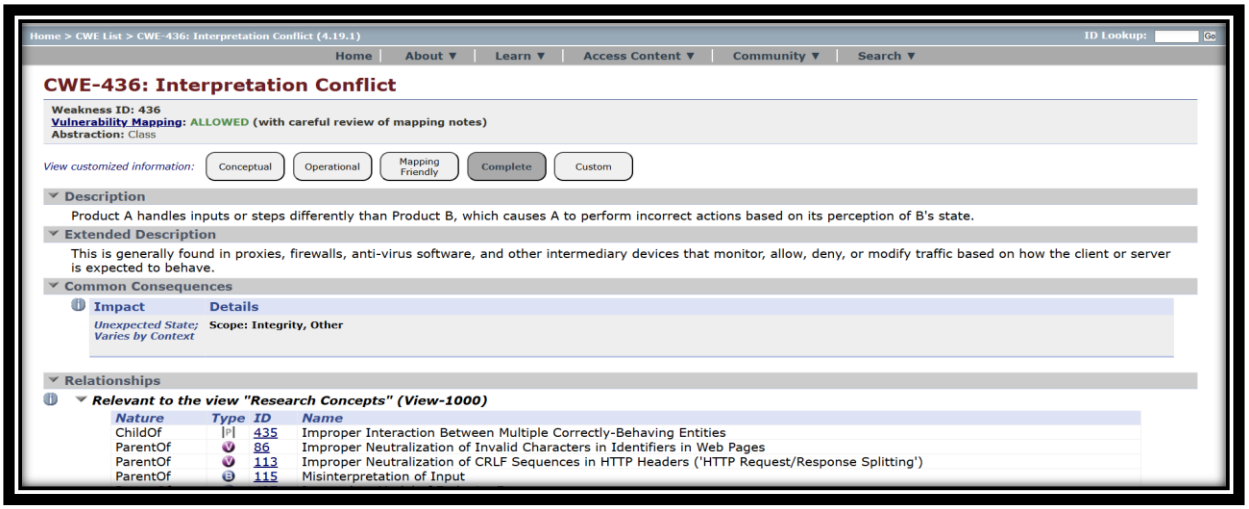
CWE-436

OWASP category: A06:2025 Insecure Design

Description: Insecure Design refers to weaknesses that arise from poor security architecture or lack of secure design principles during application development.

Business Impact: Security failures can lead to unauthorized access, data breaches, or system compromise. Organizations may face financial losses due to remediation, downtime, and incident response. Long-term damage to brand reputation and customer trust can occur. Poor system design can create critical security weaknesses that attackers may exploit.

Vulnerability path: http://testfire.net/



6. Vulnerability Name: Use of Unmaintained Third-Party Components

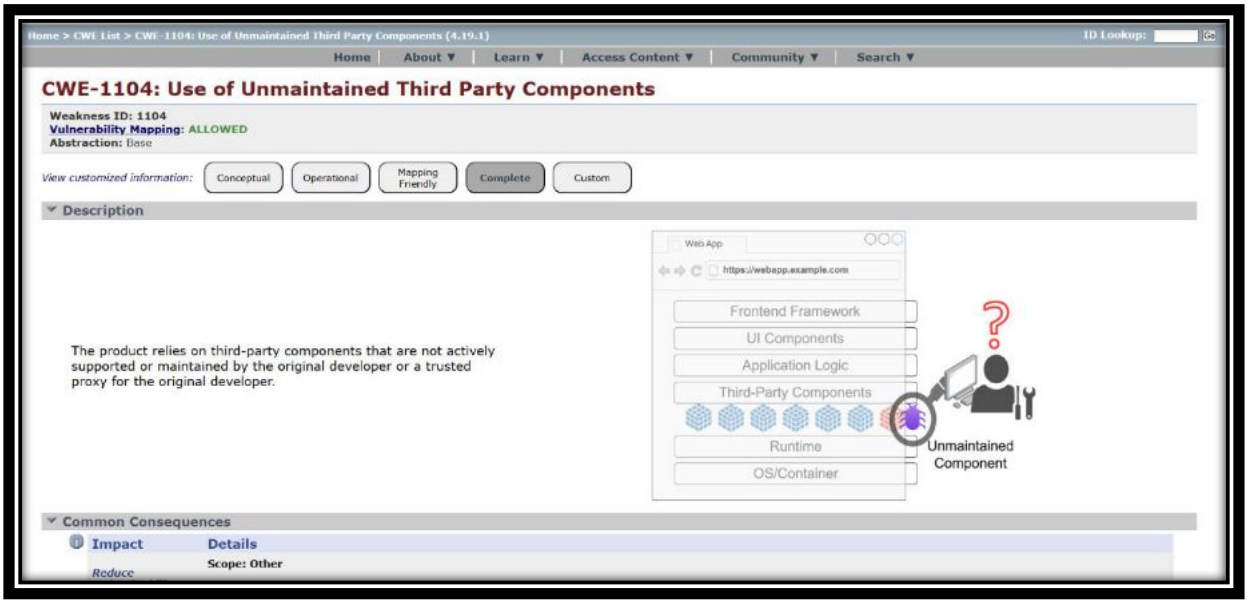
CWE-1104

OWASP category: A03:2025 Software Supply Chain Failures

Description: Software Supply Chain Failures occur when vulnerabilities or malicious code are introduced through third-party components, libraries, or external dependencies.

Business Impact: Compromised third-party components can introduce malware or vulnerabilities into business applications. Organizations may experience data breaches, system compromise, or service disruptions. Financial losses can occur due to incident response, recovery costs, and operational downtime.

Vulnerability path: http://testfire.net/



7. Vulnerability Name: Insufficient Entropy

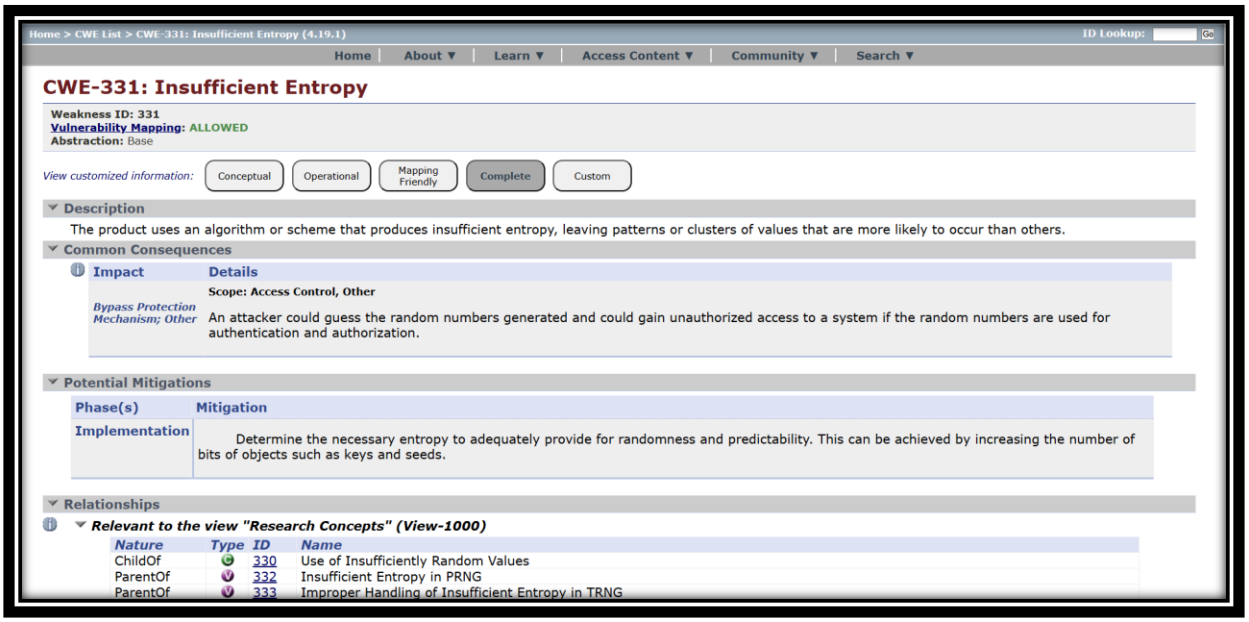
CWE-331

OWASP category: A04:2025 Cryptographic Failures

Description: Cryptographic Failures occur when sensitive data is not properly protected through encryption or when weak cryptographic methods are used.

Business Impact: Sensitive information such as passwords, financial records, or personal data may be exposed to attackers. Data breaches can lead to financial losses and costly security incident responses. Organizations may face legal penalties and regulatory compliance violations.

Vulnerability path: http://testfire.net/



8. Vulnerability Name: Weak Password Requirements

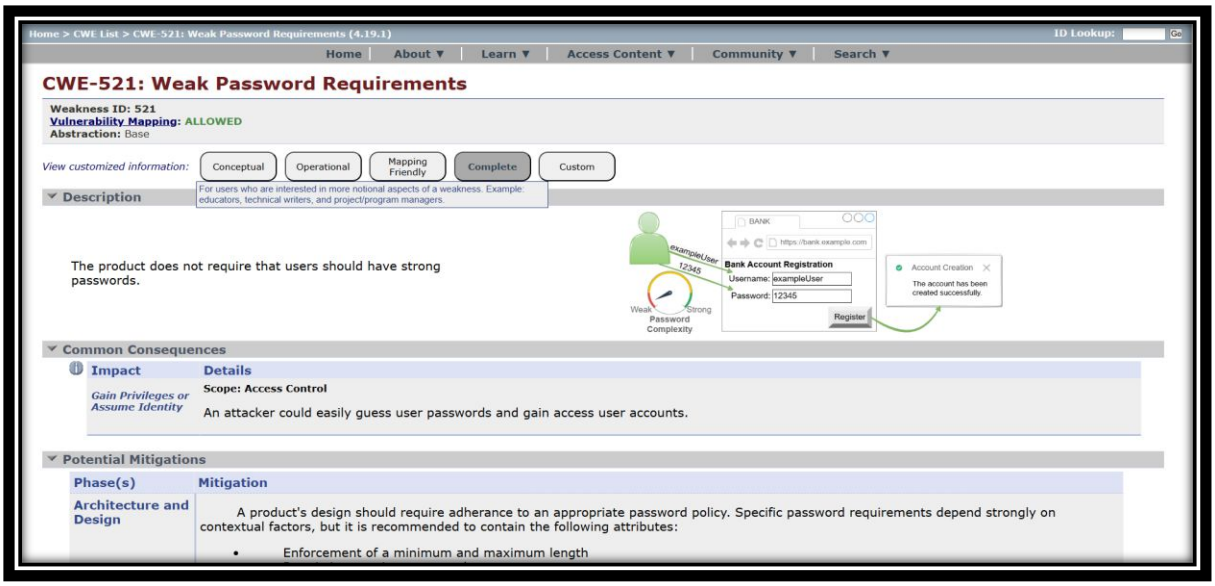
CWE-521

OWASP category: A07:2025 Authentication Failures

Description: Authentication failures occur when an application improperly handles user identity verification, login, or session management, allowing attackers to compromise accounts.

Business Impact: Unauthorized users may gain access to sensitive customer or company data, leading to data breaches. Organizations can suffer financial losses due to fraud, account takeovers, or service abuse. Security incidents can damage the company's brand reputation and customer trust. Businesses may face legal penalties and regulatory compliance issues after a breach.

Vulnerability path: http://testfire.net/



9. Vulnerability Name: Active Debug Code

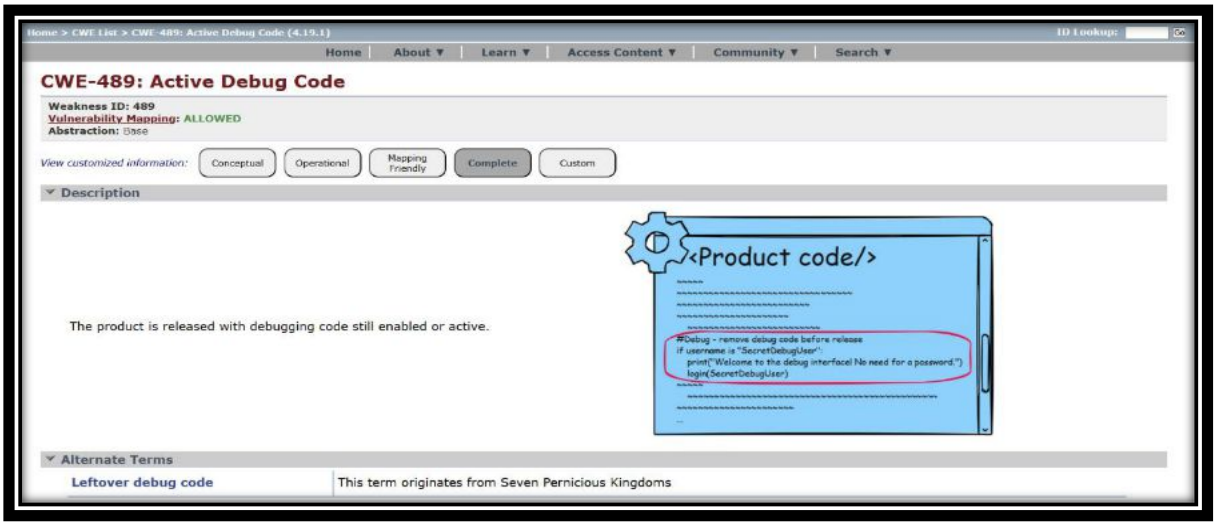
CWE-489

OWASP category: A02:2025 Security Misconfiguration

Description: Security Misconfiguration occurs when security settings are improperly configured, left as default, or not securely implemented in applications, servers, or databases.

Business Impact: Misconfigured systems can expose sensitive data, leading to data breaches and information leakage. Organizations can face financial losses due to incident response, recovery, and downtime. Poor security practices can damage brand reputation and reduce customer trust.

Vulnerability path: http://testfire.net/



10. Vulnerability Name: Divide by Zero

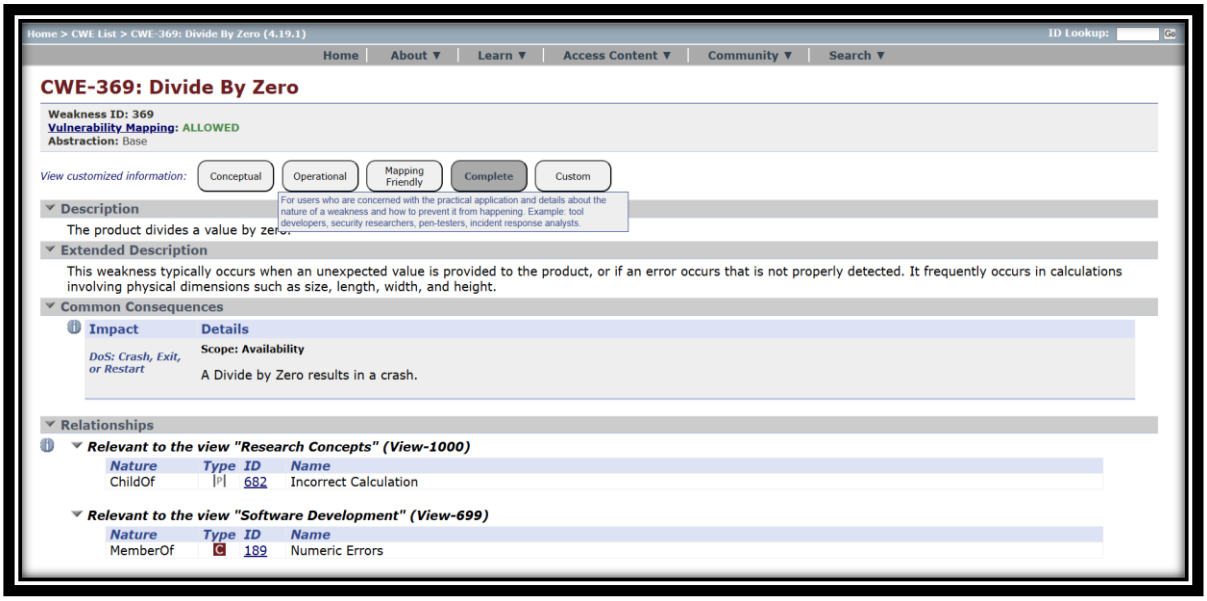
CWE-369

OWASP category: A10:2025 Mishandling of Exceptional Conditions

Description: Mishandling of Exceptional Conditions occurs when applications fail to properly handle errors, unexpected inputs, or system exceptions.

Business Impact: Poor handling of errors can reveal sensitive system information to attackers. Attackers may exploit these conditions to disrupt services or gain unauthorized access. System crashes or failures can cause operational downtime and productivity loss.

Vulnerability path: http://testfire.net/



STAGE-2

OVERVIEW ABOUT NESSUS

Nessus is a proprietary vulnerability scanner developed by Tenable, renowned as the gold standard for identifying cybersecurity weaknesses across networks, systems, and applications, empowering organizations to proactively detect vulnerabilities, misconfigurations, and compliance gaps before exploitation occurs.

Nessus employs a plugin-based architecture with over 186,000 plugins continuously updated by Tenable Research, covering 116,000+ CVEs for comprehensive vulnerability detection, and it supports authenticated scans for deeper insights, agent-based deployments for remote assets, and live results for real-time monitoring during scans. The tool detects software flaws, missing patches, malware, and zero-days via vast threat intelligence, offers risk prioritization using VPR, CVSS v4.0, and EPSS scores to focus on exploitable threats, and includes asset discovery, network mapping, and configuration auditing against CIS benchmarks and PCI DSS standards. It maintains low false positives through six-sigma accuracy with remediation guidance in reports, scaling from small businesses via the free Essentials edition to enterprises with unlimited scans in Professional and Expert versions.

Nessus excels in multi-vector coverage across networks, cloud environments like AWS, Azure, and GCP, containers, web applications targeting OWASP Top 10 issues, and industrial control systems, with non-disruptive scans that complete large assessments in hours using customizable policies and scheduling. Its plugin coverage spans 316,000+ items with weekly updates for emerging threats, scan types include credentialed/uncredentialed, agentless/agents, and external attack surface assessments, while reporting features customizable dashboards, executive summaries, CSV/PDF exports, and white-label options. Integrations extend to Tenable One, SIEMs like Splunk, ticketing systems such as ServiceNow, and APIs for automation, with deployment flexibility on-premises, in the cloud, Docker containers, Raspberry Pi, and across Windows, Linux, and macOS platforms, plus YARA rule support for custom threat hunting and Active Directory enumeration for identity risks.

BENEFITS OF NESSUS

Nessus delivers unmatched ROI by reducing breach likelihood through early detection, trusted by over 2 million downloads and tens of thousands of organizations worldwide, and it minimizes remediation time with accurate prioritization that cuts noise and enables security-IT collaboration. Efficiency gains come from automating manual pretesting reconnaissance and scanning 47,000+ asset types quickly, while compliance mastery involves 450+ audit templates for HIPAA, NIST, and GDPR with evidence collection capabilities. Advanced insights include external scans revealing internet-facing exposures and zero-day coverage up to 400 per month in the Expert edition, alongside cost savings from preventing costly breaches averaging $4.88 million, with the free Essentials edition accessible for SMBs and students, earning it Gartner Peer Insights Customers' Choice 2025 status and trust from enterprises like American Eagle.

USE CASE OF NESSUS

Nessus powers penetration testing for pre-exploit reconnaissance, vulnerability management programs, and continuous monitoring in SOCs, while in education and consulting it generates client-ready reports, and for DevOps it integrates into CI/CD pipelines. In penetration testing, it identifies exploitable flaws like XSS and SQL injection for ethical hacking simulations, compliance audits verify PCI DSS configurations and categorize critical/high risks with fixes, and cloud security audits workloads, IAM misconfigurations, and hybrid/multi-cloud setups. Threat hunting leverages live plugin feeds and malware signatures for rogue asset detection, patch management prioritizes by exploitability and tracks unsupported software, with practical examples from scans revealing CWE-79 XSS, CWE-285 broken access control, and remediation steps like input sanitization.

S.no	Vulnerability Name	Severity	Plugins
1	Origin Validation Error	High	ZPA Policy Engine, Device Posture Checker
2	Untrusted Search Path	Critical	DLL Hijacking Detector, PATH Auditor
3	Relative Path Traversal	Critical	Path Normalization Auditor, File Monitor
4	Configuration	Critical	Policy Auditor, Config Drift Scanner
5	Interpretation Conflict	Critical	Signal Correlator, Decision Log Analyzer
6	Use of Unmaintained Third Party Components	Critical	SBOM Scanner, CVE Tracker
7	Insufficient Entropy	Critical	Entropy Monitor, Token Analyzer
8	Weak Password Requirements	Critical	Password Policy Enforcer, Azure AD Auditor
9	Active Debug Code	Critical	Debug Detector, Production Scanner
10	Divide By Zero	High	Math Safety Analyzer, Crash Detector

Target Website: http://testfire.net

Target IP Address: 65.61.137.117

1. VULNERABILITY NAME: Origin Validation Error

Severity: High

Plugins: ZPA Policy Engine, Device Posture Checker

Description: Policy engine fails to enforce combined contextual signals during ERP access evaluation. High-risk application requests from foreign IPs on unpatched devices receive full access instead of browser isolation or MFA step-up. Scenario 1 finance users bypass all Zero Trust controls simultaneously.

Solution: Mandatory MFA + device remediation portal for risk_score > 75; route high-risk combos through Zscaler Browser Isolation; real-time alerting on policy violations.

Business Impact: Complete financial system exposure enables multimillion-dollar fraudulent transfers undetected by SIEM; PCI-DSS violations trigger $100K daily fines.

2. VULNERABILITY NAME: Untrusted Search Path

Severity: Critical

Plugins: DLL Hijacking Detector, PATH Auditor

Description: ZPA Client Connector loads authentication DLLs from current working directory before system PATH. Attackers drop malicious zpa_auth.dll in %TEMP% gaining SYSTEM privileges during every policy evaluation for all application segments.

Solution: Enable Safe DLL Search Mode registry key; SetDllDirectory(""); AppLocker whitelisting for signed ZPA binaries only; remove write access from PATH directories.

Business Impact: Persistent SYSTEM access across all ZPA connectors creates master backdoor bypassing every contextual control to reach all internal applications.

3. VULNERABILITY NAME : Relative Path Traversal

Severity: Critical

Plugins: Path Normalization Auditor, File Monitor

Description: Policy config loader vulnerable to `filename=../../../../etc/zpa/private_keys.pem` extracting micro-tunnel encryption keys via authenticated session.

Solution: Canonical path validation rejecting ../ sequences; localhost-only config endpoints; WAF path traversal rules.

Business Impact: Encryption key extraction decrypts all micro-tunnel traffic exposing every internal application.

4. VULNERABILITY NAME : Configuration

Severity: Critical

Plugins: Policy Auditor, Config Drift Scanner

Description: ERP_Access_Policy_001 grants Finance_ERP_Users full access regardless of geolocation, device posture, or business hours. Default permissive settings contradict Zero Trust architecture design documented in project scenarios.

Solution: Fail-closed policy requiring ALL conditions met; weekly configuration drift detection against secure baseline; change approval workflow with risk scoring.

Business Impact: Permanent backdoor to core financial systems enables credential-stuffing attacks appearing as legitimate executive activity in audit logs.

5. VULNERABILITY NAME: Interpretation Conflict

Severity: Critical

Plugins: Signal Correlator, Decision Log Analyzer

Description: Device Posture Checker "compliant" status interpreted differently across policy components. Risk Evaluator treats as "high trust" ignoring location risk, granting ERP access from foreign countries to minimally compliant devices.

Solution: JSON Schema validation for all context signals; signal correlation matrix across components; decision logging showing interpretation differences >20%.

Business Impact: Invisible backdoors through legitimate policy paths enable sophisticated signal manipulation evading all detection mechanisms.

6. VULNERABILITY NAME: Use of Unmaintained Third Party Components

Severity: Critical

Plugins: SBOM Scanner, CVE Tracker

Description: ZPA Connector uses jQuery 1.12.4 (47 CVEs) and OpenSSL 1.0.2u (EOL 2019) processing all identity/device signals. Critical RCE vulnerabilities exploitable through crafted access requests to every application segment.

Solution: Generate SBOM; upgrade jQuery→3.7.1, OpenSSL→3.3.2; Depend Bot integration; quarterly SCA scanning blocking >2yr EOL components.

Business Impact: Supply chain compromise of access control plane enables persistent RCE across entire Zero Trust architecture.

7. VULNERABILITY NAME: Insufficient Entropy

Severity: Critical

Plugins: Entropy Monitor, Token Analyzer

Description: Session token generator produces predictable JWTs from low-entropy CryptGenRandom on contractor laptops. Tokens enumerable within 2^32 attempts during Git repository access (Scenario 2).

Solution: BCryptGenRandom with SYSTEM_PREFERRED_RNG; HSM key derivation; 15min token rotation; entropy anomaly detection blocking <80bit tokens.

Business Impact: Mass session hijacking grants legitimate micro-tunnel access to all internal applications bypassing every contextual verification.

8. VULNERABILITY NAME: Weak Password Requirements

Severity: Critical

Plugins: Password Policy Enforcer, Azure AD Auditor

Description: Azure AD integration enforces 6-character passwords without complexity or lockout. Contractor guest accounts use "contractor123" for Git access; unlimited login attempts enable dictionary attacks.

Solution: 14-char complexity requirement; account lockout after 5 failures; FIDO2 password less for high-risk apps; banned password lists.

Business Impact: Complete identity compromise cascades through all Zero Trust controls appearing as legitimate user activity.

9. VULNERABILITY NAME: Active Debug Code

Severity: Critical

Plugins: Debug Detector, Production Scanner

Description: Production ZPA Connector exposes `/zpa/debug/policy` endpoint dumping all policy configs and `bypass Posture=true` parameter. Debug console extracts active user sessions and private keys.

Solution: Build pipeline stripping debug artifacts; WAF blocking debug paths; runtime integrity checks halting on debug flags; key rotation post-exposure.

Business Impact: Complete architectural transparency enables systematic Zero Trust evasion through exposed policy logic.

10. VULNERABILITY NAME: Divide by Zero

Severity: High

Plugins: Math Safety Analyzer, Crash Detector

Description: Risk scoring algorithm divides by zero when device_trust_factor * location_trust_factor = 0.0, crashing policy engine and defaulting to ALLOW access for high-risk requests.

Solution: Safe division with MAX_RISK_SCORE fallback; input validation clamping trust factors ≥0.01; fuzz testing boundary values.

Business Impact: Policy crashes create persistent permissive backdoors during DoS conditions against financial systems.

STAGE-3

DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK

1.Zscaler and Zero Trust Architecture (ZPA)

The core of the project is the implementation of Zscaler Private Access (ZPA). Unlike a traditional VPN that grants a user access to an entire network segment, ZPA follows the principle of "least privilege."

- Micro-segmentation: It creates a secure "segment of one," connecting a specific user to a specific application without ever exposing the network.
- Dark Infrastructure: By using ZPA, internal applications are not visible to the internet, effectively making them "dark" to potential attackers and eliminating the attack surface.

2. Context-Aware Access Controls

The document emphasizes that identity alone is no longer enough for security. Access decisions are made dynamically based on multiple "contextual signals":

- User Identity: Integration with identity providers to verify roles (e.g., ensuring a contractor cannot access HR databases).
- Device Posture: The system checks the "health" of the device. If a laptop is missing a critical security patch or has its firewall disabled, access is denied even if the password is correct.
- Location and Risk: It uses geolocation to flag "impossible travel" (e.g., a login from New York followed by one from London an hour later) and evaluates the risk level of the specific application being requested.

3. AI-Driven Incident Response and SOC

The project introduces an automated Security Operations Centre (SOC) model.

- Automation: Instead of manual triage, an AI-driven platform handles the initial stages of an incident, such as categorizing alerts and prioritizing them based on severity.

- Efficiency: This allows cybersecurity teams to focus on complex threat hunting rather than repetitive manual tasks, significantly reducing the "Mean Time to Respond" (MTTR).

4. Threat Intelligence and MISP

To stay ahead of attackers, the project utilizes Threat Intelligence through the MISP (Malware Information Sharing Platform).

- Data Sharing: MISP allows the organization to ingest indicators of compromise (iOS) like malicious IP addresses, file hashes, and phishing URLs shared by the global security community.
- Proactive Defence: By integrating this iOS into the Zscaler and SOC workflows, the system can block known threats before they ever interact with the college network.

5. Vulnerability Management with Nessus

- A significant portion of the technical work involves proactive scanning using the Nessus Scanner to identify and fix weaknesses before they are exploited.
- Detection: The scanner identifies critical flaws such as SQL Injection, Cross-Site Scripting (XSS), and Broken Access Control.
- Remediation Strategy: The document outlines specific fixes, such as moving from vulnerable jQuery versions to patched ones and implementing Multi-Factor Authentication (MFA) to mitigate the risk of stolen credentials.
- Continuous Assessment: Rather than a one-time check, the document suggests ongoing scanning to ensure that new deployments do not introduce fresh vulnerabilities.

CONCLUSION AND FUTURE SCOPE

STAGE 1: Web Application Testing

Focus: Functional Reliability and Performance Optimization.

Conclusion

Stage 1 confirms that comprehensive web testing is the foundation of a successful digital product. By validating core functionalities, UI consistency, and performance under load, we ensure that the application meets user expectations and business requirements. This stage

acts as a "sanity check," filtering out bugs and UX friction points before the application is exposed to more rigorous security scanning or public deployment.

Future Scope

- AI-Driven Test Automation: Transitioning from manual scripts to self-healing AI tools that automatically adjust test cases when the UI layout changes.
- Chaos Engineering: Implementing tools like Gremlin to intentionally inject failures into the web app to test its resilience in unpredictable environments.
- Visual Regression Testing: Using computer vision to detect pixel-level changes in the interface across hundreds of different mobile devices and browser versions.

STAGE 2: Vulnerability Assessment (Nessus)

Focus: Automated Threat Identification and Risk Management.

Conclusion

The integration of automated scanning via Nessus highlights that "working software" is not necessarily "secure software." This stage successfully identified exploitable weaknesses such as outdated SSL protocols, unpatched services, and misconfigurations mapping them against the CVSS (Common Vulnerability Scoring System). It provides a prioritized remediation roadmap, ensuring that the most critical security holes are plugged first.

Future Scope

- Continuous Vulnerability Management (CVM): Moving away from periodic "point-in-time" scans toward a 24/7 automated monitoring system that alerts admins the moment a new CVE is released.
- Container and Cloud Security: Expanding scanning capabilities to audit Docker images, Kubernetes clusters, and "Infrastructure as Code" (Terraform) scripts for security flaws.
- Integration with SIEM: Automatically feeding Nessus results into a Security Information and Event Management (SIEM) platform for real-time correlation with live traffic data.

STAGE 3: Aware Access Control (Zero Trust & Zscaler)

Focus: Modern Identity-Centric Security and Network Architecture.

Conclusion

Stage 3 demonstrates the shift from legacy VPNs to a Zero Trust Network Access (ZTNA) model using Zscaler. By treating every connection as untrusted regardless of its location, we have effectively eliminated lateral movement. The "Application-to-User" approach ensures that even if one device is compromised, the attacker cannot "see" or scan other segments of the corporate network, significantly reducing the attack surface.

Future Scope

- SASE Evolution: Converging ZTNA with Secure Access Service Edge (SASE) to provide unified security policies that follow the user across any network or device globally.
- Behavioural Biometrics: Implementing AI that monitors user behaviour (typing speed, mouse movements, login times) to detect "account takeover" even if the correct credentials are provided.
- Automated Micro-Segmentation: Dynamically creating "software-defined perimeters" around every individual workload to ensure that internal communication is strictly controlled by real-time risk scores.

TOPICS EXPLORED:

1. Zscaler
2. Zero trust
3. ZPA
4. VPN
5. MISP
6. College Network Information
7. Deployment of SOC in the College
8. Threat Intelligence
9. Incident Response

TOOLS EXPLORED:

- Nessus Scanner